

Threat Hunting, Mapping Adversary TTPs Using MITRE ATT&CK

TASK 1. Industry Threat Landscape (Threat Intelligence)

The United Kingdom banking sector is identified as a high-value target due to the cruciality of its services, the sensitivity and volume of information processed, its systemic importance to national and international financial stability, and its exposure to sophisticated threat actors. UK banking institutions process and store: Financial transaction data, Personally Identifiable Information (PII), Authentication credentials, and Corporate and government financial records. The sector's deep digital integration and role in global sanctions enforcement further increase its attractiveness as a target.

This information is highly attractive for financial crime, fraud, espionage, and extortion.

Task 1b: APT groups associated with the industry.

The screenshot shows the SOCradar website interface. On the left is a dark blue sidebar with the SOCradar logo and a list of tools: Dark Web Report, IOC Radar, Threat Reports, External Attack Surface, Threat Actor (highlighted with a 'New' badge), CVE Radar, Campaigns, SOC Tools, and BlueBleed. Below these is a red 'Access Now' button and links for Company, Partners, and Contact. The main content area has a light blue header with a search bar containing 'socradar.io/labs/threat-actor/detail//533/INDRIK%20SPIDER'. Below the header, the title 'INDRIK SPIDER' is displayed. To the right of the title is a 'No Description available.' message. Below the title is a blue badge showing '★ Rank: 381' and a profile picture of a person in a dark hoodie with glowing eyes. Below the picture is a red button that says 'Get Free Access to Insights'. Underneath is the section 'Also Known As:' followed by a row of buttons: UNC2165, Mustard Tempest, Gold Drake, DEV-0243, Manatee Tempest, and a '+5' button. Below this is a horizontal menu with tabs: Details (selected), Mitre ATT&CK, IOC, Yara / Sigma Rules, and References. The 'Details' tab is active, showing 'Target Countries' with buttons for Germany, United Kingdom, and United States, and 'Target Sectors' with buttons for Finance, HealthCare & Social Assistance, Public Administration, Insurance, and Banking.

INDRIK SPIDER

Indrik Spider, also known as Evil Corp, is a highly sophisticated Russian cybercriminal syndicate active since at least 2014. Best known for developing the Dridex banking Trojan and orchestrating large-scale ransomware campaigns, the group has targeted high-profile sectors worldwide, including healthcare and finance, causing severe monetary and operational damages.

Also Known As: UNC2165, Gold Drake, DEV-0243, Manatee Tempest.

Target Sectors: Finance, Insurance, Banking, Healthcare, and Social Assistance
Tactics: Primarily focuses on financial theft through ransomware and banking malware.

Techniques: Employs phishing schemes, advanced persistence threats (APTs), and credential theft to infiltrate systems. Techniques often involve the deployment of malware and ransomware

Procedures: Their methods include initial access through phishing campaigns, exploitation of unpatched vulnerabilities, and code signing to evade detection. Once inside, they exfiltrate data, encrypt systems, and employ double extortion by threatening to leak sensitive information unless the ransom is paid.

Primary Motive: Monetary gain and large-scale data disruption.

← → ↻ socradar.io/labs/threat-actor/detail//561/APT-C-36



FREE TOOLS

- Dark Web Report
- IOC Radar
- Threat Reports
- External Attack Surface
- Threat Actor** New
- CVE Radar
- Campaigns
- SOC Tools
- BlueBleed

Get free access to more tools from SOCRadar

Access Now

Company Partners Contact

APT-C-36

No Description available.

★ Rank: 37



Get Free Access to Insights

Also Known As:

AguilaCiega APT-C-36 G0099 APT-Q-98 Blind Eagle

Details Mitre ATT&CK IOC Yara / Sigma Rules References

Target Countries

Afghanistan Argentina Austria Australia Azerbaijan +36

Target Sectors

Manufacturing Public Administration Oil & Gas Educational Services Space & Defense +14

Associated Malware/Software

APT-C-36

APT-C-36 Also known as Blind Eagle, is a threat group that engages in both espionage and cybercrime. It primarily targets organizations in Colombia and other Latin American countries. Active since 2018.

Also Known As: Blind Eagle, APT-Q-98, AguilaCiega

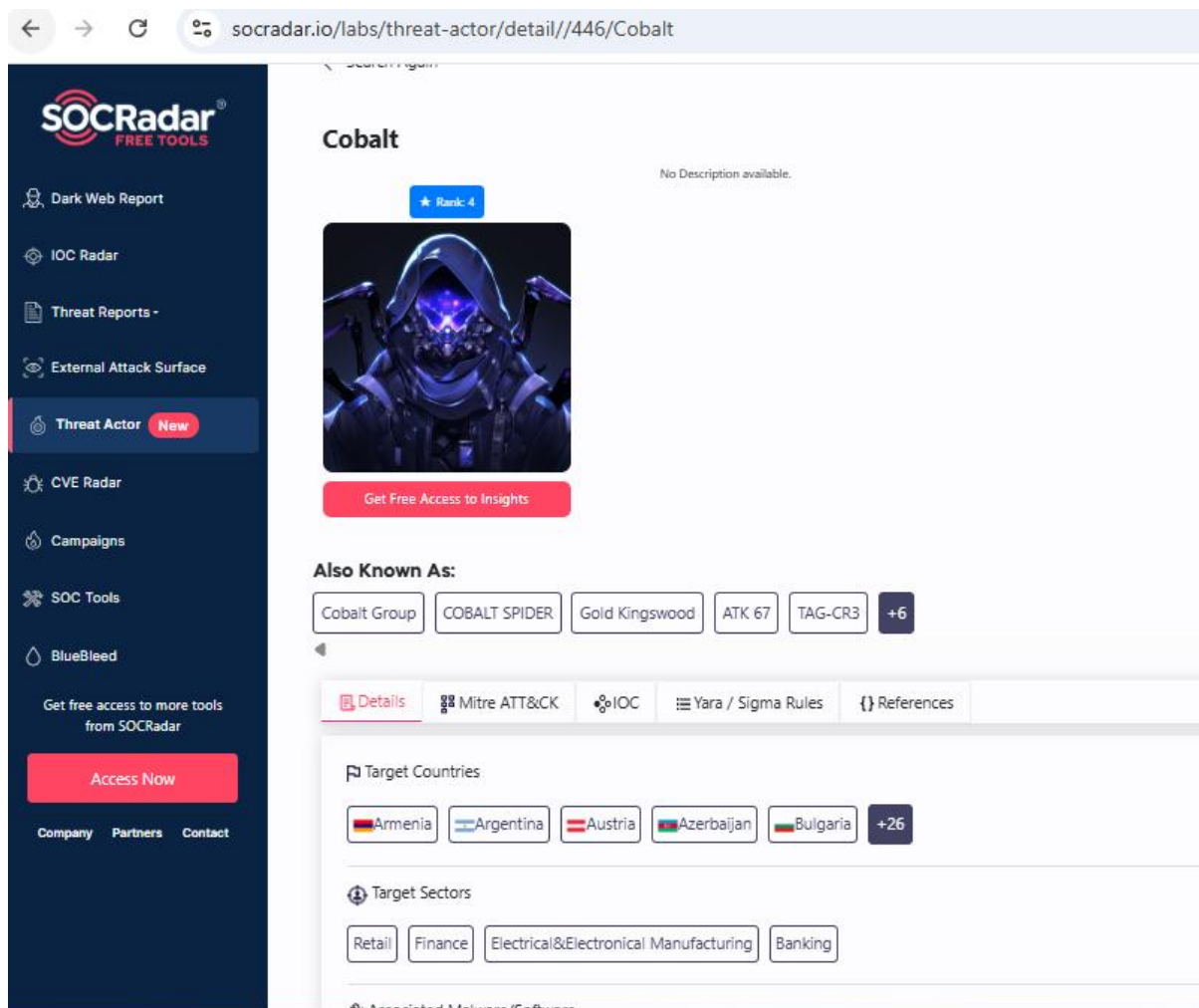
Target Sectors: Banking, Oil & Gas, Energy & Utilities

Tactics/Technics: Spear phishing (including ClickFix), Vulnerabilities & exploits, Malware implant

Procedure: Blind Eagle is known for employing sophisticated social engineering tactics, using phishing emails with malicious attachments or links to gain initial access to target systems.

Impact: Data breaches and significant financial

Primary Motive: Financial gain.



Cobalt Group

Cobalt Group, also known as Cobalt Gang, is a financially motivated cybercrime organization that emerged around 2016 and is known for its sophisticated, large-scale attacks on banks, ATMs, and payment systems.

Target Sectors: Retail, Finance, Banking

Tactics: Employing methods such as ATM jackpotting, SWIFT system manipulation, and wire fraud.

Techniques: Spear-phishing campaigns to gain initial access, attaching malicious documents, and exploiting vulnerabilities in Microsoft Office. Collection of data from cloud storage.

Procedure: The group moves laterally within compromised environments. To execute attacks, they manipulate SWIFT systems and remote ATMs.

Primary Motive: Theft of funds from financial institutions.

socradar.io/labs/threat-actor/detail//2535/Unit%2029155



FREE TOOLS

- Dark Web Report
- IOC Radar
- Threat Reports
- External Attack Surface
- Threat Actor** New
- CVE Radar
- Campaigns
- SOC Tools
- BlueBleed

Get free access to more tools from SOCRadar

Access Now

Company Partners Contact

Unit 29155

No Description available.

★ Rank: 341



Get Free Access to Insights

Also Known As:

Frozensvita DEV-0586 Bleeding Bear 161st Specialist Training Center UNC2589 +5

Details Mitre ATT&CK IOC Yara / Sigma Rules References

Target Countries

Armenia Azerbaijan Bulgaria Canada Switzerland +32

Target Sectors

Energy & Utilities Transportation&Warehousing Finance HealthCare & Social Assistance Public Administration +2

Unit 29155

Unit 29155 is a Russian state-sponsored cyber espionage group closely tied to the GRU. Known for spear-phishing and wiper malware like WhisperGate, they target critical infrastructure, governments, and defence sectors, often leveraging destructive tactics alongside data theft.

Also Known As: Ember Bear, Bleeding Bear, DEV-0586, Frozensvita

Target Sectors: Finance, Bank, Energy & Utilities

Tactics: Espionage and long-term intelligence gathering but has demonstrated capability for wiper attacks.

Techniques: Spear phishing, with malicious documents, persistence through web shells.

Procedures: Procedures involve deploying tools like WhisperGate wiper malware, document stealers such as Out-Steel, and backdoor malware such as Graph-Steel and GrimPlant.

Impact: Destruction of data

Primary Motive: Data Theft, Financial gain.

← → ↻ socradar.io/labs/threat-actor/detail//390/SHARK%20SPIDER



FREE TOOLS

- Dark Web Report
- IOC Radar
- Threat Reports ▾
- External Attack Surface
- Threat Actor** New
- CVE Radar
- Campaigns
- SOC Tools
- BlueBleed

Get free access to more tools from SOCRadar

Access Now

Company Partners Contact

SHARK SPIDER

No Description available.

★ Rank: 12



[Get Free Access to Insights](#)

Also Known As:

Oktapus Octo Tempest UNC3944 Storm-0875 ShinyHunters +2

Details Mitre ATT&CK IOC Yara / Sigma Rules

Target Countries

Australia Canada United Kingdom India United States

Target Sectors

Retail Accommodation&Food Services Air Transportation Insurance Banking

SHARK SPIDER

Shark Spider, also known as Scattered Spider, UNC3944, and Muddled Libra, is a prominent cybercriminal group active since at least 2022 (CISA). The collective is notorious for social engineering schemes, advanced phishing campaigns, and the use of Ransomware-as-a-Service (RaaS).

Also Known As: Scattered Spider, UNC3944, Roasted Oktapus

Target Sectors: Banking, Oil & Gas, Energy & Utilities

Tactics: Data exfiltration and ransomware attacks.

Techniques: Exploitation of cloud platform, Phishing, Social Engineering; MFA Fatigue (flooding users with authentication requests). Helpdesk impersonation to request credentials or authentication codes.

Procedures: Deploying malware, including Spectre RAT, Raccoon Stealer, and BlackCat ransomware, hosting short-lived phishing domains for data exfiltration, and embedding within compromised organizations by monitoring internal communications.

Primary Motive: Data theft, extortion, and ransomware deployment.

TASK 2.

TTP Analysis Using MITRE ATT&CK

TTP Analysis for INDRIK SPIDER

Tactics	ID	Techniques used
Credential Access	T1555	Credentials from Password Stores
Lateral Movement	T1570	Lateral Tool Transfer
Command and control	T1001	Data Obfuscation
Exfiltration	T1567	Exfiltration Over Web Service
Impact	T1486	Data Encrypted for Impact
Initial Access	T1566	Phishing

The screenshot displays the SOCRadar Threat Actor interface. On the left is a dark sidebar with navigation links: Dark Web Report, DDoS Report, IOC Radar, Threat Reports, External Attack Surface, Threat Actor (highlighted with a 'New' badge), CVE Radar, Campaigns, SOC Tools, and BlueBleed. At the bottom of the sidebar is a red button labeled 'Access Now'. The main content area features a search bar with a dropdown menu set to 'Tactics' and a search input field containing 'Search tactic or technique name'. Below the search bar is a table listing MITRE ATT&CK techniques. The table has three columns: 'Tactic', 'Id', and 'Technique'. Each row includes links for 'Sub Techniques', 'Detections', and 'Mitigations'. The techniques listed are: Collection (T1056) Input Capture, Collection (T1074) Data Staged, Collection (T1113) Screen Capture, Collection (T1005) Data from Local System, Command And Control (T1001) Data Obfuscation, Command And Control (T1568) Dynamic Resolution, Command And Control (T1132) Data Encoding, Command And Control (T1105) Ingress Tool Transfer, and Command And Control (T1102) Web Service. An 'Activate Windows' watermark is visible in the bottom right corner of the screenshot.

Tactic	Id	Technique	Sub Techniques	Detections	Mitigations
Collection	T1056	Input Capture	Sub Techniques	Detections	Mitigations
Collection	T1074	Data Staged	Sub Techniques	Detections	Mitigations
Collection	T1113	Screen Capture	Sub Techniques	Detections	Mitigations
Collection	T1005	Data from Local System	Sub Techniques	Detections	Mitigations
Command And Control	T1001	Data Obfuscation	Sub Techniques	Detections	Mitigations
Command And Control	T1568	Dynamic Resolution	Sub Techniques	Detections	Mitigations
Command And Control	T1132	Data Encoding	Sub Techniques	Detections	Mitigations
Command And Control	T1105	Ingress Tool Transfer	Sub Techniques	Detections	Mitigations
Command And Control	T1102	Web Service	Sub Techniques	Detections	Mitigations

TTP Analysis for APT-C-36 Group

Tactics	ID	Techniques used
Credential Access	T1557	Adversary-in-the-Middle
Credential Access	T1003	OS Credential Dumping
Command and control	T1573	Encrypted Channel
Command and control	T1001	Data Obfuscation
Exfiltration	T1567	Exfiltration Over Web Service
Exfiltration	T1011	Exfiltration Over Other Network Medium
Impact	T1531	Account Access Removal
Discovery	T1016	System Network Configuration Discovery
Initial Access	T1078	Valid Accounts



- Dark Web Report
- DDoS Report
- IOC Radar
- Threat Reports
- External Attack Surface
- Threat Actor New**
- CVE Radar
- Campaigns
- SOC Tools
- BlueBleed

Get free access to more tools from SOCRadar

[Access Now](#)

Tactic	Id	Technique			
Collection	T1557	Adversary-in-the-Middle	Sub Techniques	Detections	Mitigations
Collection	T1056	Input Capture	Sub Techniques	Detections	Mitigations
Collection	T1113	Screen Capture	Sub Techniques	Detections	Mitigations
Collection	T1005	Data from Local System	Sub Techniques	Detections	Mitigations
Command And Control	T1573	Encrypted Channel	Sub Techniques	Detections	Mitigations
Command And Control	T1001	Data Obfuscation	Sub Techniques	Detections	Mitigations
Command And Control	T1568	Dynamic Resolution	Sub Techniques	Detections	Mitigations
Command And Control	T1095	Non-Application Layer Protocol	Sub Techniques	Detections	Mitigations
Command And Control	T1102	Web Service	Sub Techniques	Detections	Mitigations
Command And Control	T1571	Non-Standard Port	Sub Techniques	Detections	Mitigations
Command And Control	T1132	Data Encoding	Sub Techniques	Detections	Mitigations

Activate Windows
Go to Settings to activate Windows

TTP Analysis for Cobalt Group

Tactics	ID	Techniques used
Credential Access	T1503	Credentials from Web Browsers
Credential Access	T1552	Unsecured Credentials
Lateral Movement	T1097	Pass the Ticket
Lateral Movement	T1506	Web Session Cookie
Command and control	T1071	Application Layer Protocol
Command and control	T1573	Encrypted Channel
Exfiltration	T1041	Exfiltration Over C2 Channel
Exfiltration	T1567	Exfiltration Over Web Service
Initial Access	T1195	Supply Chain Compromise
Initial Access	T1078	Valid Accounts
Persistence	T1053	Scheduled Task/Job
Collection	T1119	Automated Collection

socradar.io/labs/threat-actor/detail/446/Cobalt

Cobalt Gang Cobalt Group TAG-CR3 Mule Libra GOLD KINGSWOOD +6

Details **Mitre ATT&CK** IOC Yara / Sigma Rules References

Tactics Search tactic or technique name

Tactic	Id	Technique	Sub Techniques	Detections	Mitigations
Collection	T1119	Automated Collection	Sub Techniques	Detections	Mitigations
Collection	T1074	Data Staged	Sub Techniques	Detections	Mitigations
Collection	T1560	Archive Collected Data	Sub Techniques	Detections	Mitigations
Collection	T1113	Screen Capture	Sub Techniques	Detections	Mitigations
Collection	T1185	Browser Session Hijacking	Sub Techniques	Detections	Mitigations
Collection	T1114	Email Collection	Sub Techniques	Detections	Mitigations
Collection	T1115	Clipboard Data	Sub Techniques	Detections	Mitigations

Activate Windows
Go to Settings to activate Windows.

TTP Analysis for Unit 29155

Tactics	ID	Techniques used
Credential Access	T1552	Unsecured Credentials
Credential Access	T1110	Brute Force
Lateral Movement	T1570	Lateral Tool Transfer
Lateral Movement	T1210	Exploitation of Remote Services
Command and control	T1071	Application Layer Protocol
Command and control	T1572	Protocol Tunnelling
Initial Access	T1195	Supply Chain Compromise
Initial Access	T1133	External Remote Services
Exfiltration	T1567	Exfiltration Over Web Service
Collection	T1125	Video Capture
Persistence	T1053	Scheduled Task/Job

Dark Web Report

DDoS Report

IOC Radar

Threat Reports -

External Attack Surface

Threat Actor New

CVE Radar

Campaigns

SOC Tools

BlueBleed

Get free access to more tools from SOCRadar

[Access Now](#)

Also Known As:

Ember Bear UAC-0056 Frozenvista GRU Unit 29155 Ruinous Ursa +5

Details **Mitre ATT&CK** IOC Yara / Sigma Rules References

Tactics

Tactic	Id	Technique	Sub Techniques	Detections	Mitigations
Collection	T1125	Video Capture	Sub Techniques	Detections	Mitigations
Collection	T1119	Automated Collection	Sub Techniques	Detections	Mitigations
Collection	T1005	Data from Local System	Sub Techniques	Detections	Mitigations
Collection	T1114	Email Collection	Sub Techniques	Detections	Mitigations
Collection	T1213	Data from Information Repositories	Sub Techniques	Detections	Mitigations
Collection	T1560	Archive Collected Data	Sub Techniques	Detections	Mitigations

Page 11 of 11 812 words Text Predictions: On Accessibility: Investigate

Activate Windows
Go to Settings to activate Windows.

TTP Analysis for SHARK SPIDER

Tactics	ID	Techniques Name
Initial Access	T1566	Phishing
Command and control	T1071	Application Layer Protocol
Execution	T1059	Command and Scripting Interpreter

Get Free Access to Insights

Also Known As:

Octo Tempest UNC3944 Muddled Libra Storm-0875 ShinyHunters +3

Details **Mitre ATT&CK** IOC Yara / Sigma Rules

Tactics Search tactic or technique name

Tactic	Id	Technique	Sub Techniques	Detections	Mitigations
Command And Control	T1071	Application Layer Protocol	Sub Techniques	Detections	Mitigations
Execution	T1059	Command and Scripting Interpreter	Sub Techniques	Detections	Mitigations
Initial Access	T1566	Phishing	Sub Techniques	Detections	Mitigations

Activate Windows
Go to Settings to activate Wi

Copyright © 2025 SOCRadar Cyber Intelligence Inc.
All rights reserved.

TASK 3

ATT&CK Navigator Mapping & Overlap Analysis

In this task, I mapped each APT to its TTPs using the MITRE ATT&CK Navigator. Mapping APTs to their TTPs is essential in cyber defence. Some of the importance lies in helping detect attacks earlier, mapping APTs to

Mapping INDRIK SPIDER to its TTPs

Mapping APT-C-36 to its TTPs.

[illegible]

Mapping Cobalt Group to its TTPs.

mitre-attack.github.io/attack-navigator/

INDRIK SPIDER x APT-C-36 x COBALT x UNIT 29155 x SHARK SPIDER x

Selection Controls Layer Controls Technique Controls

Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
11 techniques	17 techniques	23 techniques	14 techniques	47 techniques	17 techniques	34 techniques	9 techniques	17 techniques	18 techniques	9 techniques	15 techniques
Initial Access	Cloud Administration Command	Account Manipulation (0/7)	Abuse Elevation Control Mechanism (1/6)	Abuse Elevation Control Mechanism (1/6)	Adversary-in-the-Middle (0/4)	Account Discovery (0/4)	Exploitation of Remote Services (0/4)	Adversary-in-the-Middle (0/4)	Application Layer Protocol (2/5)	Automated Exfiltration (0/1)	Account Access Removal (0/1)
Initial Access	Command and Scripting Interpreter (4/13)	BITS Jobs	Access Token Manipulation (0/5)	Access Token Manipulation (0/5)	Brute Force (0/4)	Application Window Discovery (0/4)	Internal Spearphishing (0/4)	Archive Collected Data (0/3)	Communication Through Removable Media (0/2)	Data Transfer Size Limits (0/1)	Data Destruction (0/1)
Initial Access	Container Administration Command	Boot or Logon Autostart Execution (1/14)	Account Manipulation (0/7)	Build Image on Host (0/7)	Credentials from Password Stores (0/6)	Browser Information Discovery (0/4)	Lateral Tool Transfer (0/2)	Audio Capture (0/3)	Content Injection (0/2)	Exfiltration Over Alternative Protocol (0/3)	Data Encrypted for Impact (0/2)
Initial Access	Deploy Container	Boot or Logon Initialization Scripts (1/5)	Deobfuscate/Decode Files or Information (0/7)	Debugger Evasion (0/2)	Exploitation for Credential Access (0/4)	Cloud Infrastructure Discovery (0/4)	Remote Service Session Hijacking (0/2)	Automated Collection (0/3)	Data Encoding (0/2)	Defacement (0/2)	Data Manipulation (0/2)
Initial Access	ESXi Administration Command	Cloud Application Integration (1/14)	Boot or Logon Autostart Execution (1/14)	Delay Execution (0/2)	Forced Authentication (0/2)	Cloud Service Dashboard (0/2)	Remote Services (1/8)	Browser Session Hijacking (0/3)	Data Obfuscation (0/3)	Disk Wipe (0/2)	Defacement (0/2)
Initial Access	Exploitation for Client Execution	Compromise Host Software Binary (0/3)	Boot or Logon Initialization Scripts (1/5)	Deobfuscate/Decode Files or Information (0/2)	Forge Web Credentials (0/2)	Cloud Storage Object Discovery (0/2)	Replication Through Removable Media (0/2)	Clipboard Data (0/3)	Dynamic Resolution (0/3)	Endpoint Denial of Service (0/4)	Disk Wipe (0/2)
Initial Access	Input Injection	Create Account (0/3)	Create or Modify System Process (1/5)	Domain or Tenant Policy Modification (0/2)	Input Capture (0/4)	Container and Resource Discovery (0/4)	Software Deployment Tools (0/2)	Data from Cloud Storage (0/2)	Encrypted Channel (1/2)	Exfiltration Over Other Network Medium (0/1)	Email Bombing (0/2)
Initial Access	Inter-Process Communication (1/3)	Create or Modify System Process (1/5)	Create or Modify System Process (1/5)	Email Spoofing (0/2)	Modify Authentication Process (0/9)	Device Driver Discovery (0/2)	Taint Shared Content (0/2)	Data from Configuration Repository (0/2)	Fallback Channels (0/1)	Financial Theft (0/4)	Email Bombing (0/2)

Go to settings to activate Windows

legend

Mapping Unit 29155 to its TTPs.

mitre-attack.github.io/attack-navigator/

INDRIK SPIDER x APT-C-36 x COBALT x UNIT 29155 x SHARK SPIDER x

Selection Controls Layer Controls Technique Controls

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control
11 techniques	8 techniques	11 techniques	17 techniques	23 techniques	14 techniques	47 techniques	17 techniques	34 techniques	9 techniques	17 techniques	18 techniques
Active Scanning (2/3)	Acquire Access	Content Injection	Cloud Administration Command	Account Manipulation (0/7)	Abuse Elevation Control Mechanism (0/6)	Abuse Elevation Control Mechanism (0/6)	Adversary-in-the-Middle (0/4)	Account Discovery (0/4)	Exploitation of Remote Services (0/4)	Adversary-in-the-Middle (0/4)	Application Layer Protocol (2/5)
Gather Victim Host Information (0/4)	Acquire Infrastructure (1/8)	Drive-by Compromise	Command and Scripting Interpreter (1/13)	BITS Jobs	Access Token Manipulation (0/5)	Access Token Manipulation (0/5)	Brute Force (1/4)	Application Window Discovery (0/4)	Internal Spearphishing (0/4)	Archive Collected Data (0/3)	Communication Through Removable Media (0/2)
Gather Victim Identity Information (0/3)	Compromise Accounts (0/3)	Exploit Public-Facing Application	Container Administration Command	Boot or Logon Autostart Execution (0/14)	Account Manipulation (0/7)	Build Image on Host (0/7)	Credentials from Password Stores (0/6)	Browser Information Discovery (0/4)	Lateral Tool Transfer (0/3)	Audio Capture	Content Injection
Gather Victim Network Information (0/6)	Compromise Infrastructure (0/8)	External Remote Services	Deploy Container	Boot or Logon Initialization Scripts (0/5)	Exploitation for Credential Access (0/4)	Debugger Evasion (0/2)	Exploitation for Credential Access (0/4)	Cloud Service Dashboard (0/2)	Remote Service Session Hijacking (0/2)	Automated Collection (0/3)	Data Encrypted for Impact (0/2)
Gather Victim Org Information (0/4)	Develop Capabilities (0/4)	Hardware Additions	ESXi Administration Command	Cloud Application Integration (0/14)	Forced Authentication (0/2)	Deobfuscate/Decode Files or Information (0/2)	Forced Authentication (0/2)	Cloud Service Discovery (0/3)	Browser Session Hijacking (0/3)	Defacement (0/2)	Data Manipulation (0/2)
Phishing for Information (0/4)	Establish Accounts (0/3)	Phishing	Exploitation for Client Execution	Compromise Host Software Binary (0/3)	Forge Web Credentials (0/2)	Delay Execution (0/2)	Forge Web Credentials (0/2)	Cloud Storage Object Discovery (0/3)	Clipboard Data (0/3)	Disk Wipe (0/2)	Defacement (0/2)
Search Closed Sources (0/2)	Obtain Capabilities (2/7)	Replication Through Removable Media	Input Injection	Boot or Logon Autostart Execution (0/5)	Domain or Tenant Policy Modification (0/2)	Direct Volume Access (0/2)	Input Capture (0/4)	Container and Resource Discovery (0/2)	Data from Cloud Storage (0/2)	Endpoint Denial of Service (0/4)	Disk Wipe (0/2)
Search Open Technical Databases (0/3)	Stage Capabilities (0/6)	Supply Chain Compromise (0/3)	Inter-Process Communication (0/3)	Create Account (0/3)	Email Spoofing (0/2)	Execution Guardrails (0/2)	Modify Authentication Process (0/9)	Debugger Evasion (0/2)	Data from Configuration Repository (0/2)	Financial Theft (0/4)	Disk Wipe (0/2)
Search Open Websites/Domains				Create or Modify System Process (0/5)				Device Driver Discovery (0/2)	Fallback Channels (0/1)	Inhibit System Recovery (0/1)	Disk Wipe (0/2)

Go to settings to activate Windows

legend

Mapping SHARK SPIDER to its TTPs.

mitre-attack.github.io/attack-navigator/

INDRIK SPIDER x APT-C-36 x COBALT x UNIT 29155 x SHARK SPIDER x

Selection Controls Layer Controls Technique Controls

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Comr and Cr
11 techniques	8 techniques	11 techniques	17 techniques	23 techniques	14 techniques	47 techniques	17 techniques	34 techniques	9 techniques	17 techniques	18 techniques
Active Scanning (0/3)	Acquire Access	Content Injection	Cloud Administration Command	Account Manipulation (3/7)	Abuse Elevation Control Mechanism (0/6)	Abuse Elevation Control Mechanism (1/6)	Adversary-in-the-Middle (0/4)	Account Discovery (3/4)	Exploitation of Remote Services (0/4)	Adversary-in-the-Middle (0/4)	Application Layer Pro (0/5)
Gather Victim Host Information (0/4)	Acquire Infrastructure (1/8)	Drive-by Compromise	Command and Scripting Interpreter (2/13)	BITS Jobs	Access Token Manipulation (0/5)	Access Token Manipulation (0/5)	Brute Force (0/4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (0/3)	Commun Through Removab Media
Gather Victim Identity Information (1/3)	Compromise Accounts (0/3)	Exploit Public-Facing Application	Container Administration Command	Boot or Logon Autostart Execution (0/14)	Account Manipulation (0/5)	Build Image on Host	Credentials from Password Stores (1/6)	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Content Injection
Gather Victim Network Information (0/6)	Compromise Infrastructure (0/6)	External Remote Services	Deploy Container	Boot or Logon Initialization Scripts (0/5)	Account Manipulation (3/7)	Debugger Evasion	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (0/2)	Automated Collection	Data Encr (0/2)
Gather Victim Org Information (0/4)	Develop Capabilities (0/4)	Hardware Additions	ESXi Administration Command	Cloud Application Integration	Boot or Logon Autostart Execution (0/14)	Deobfuscate/Decode Files or Information	Forced Authentication	Cloud Service Dashboard	Remote Services (3/8)	Browser Session Hijacking	Data Obfuscati (0/3)
Phishing for Information (2/4)	Establish Accounts (1/3)	Phishing (1/4)	Exploitation for Client Execution	Compromise Host Software Binary	Boot or Logon Initialization Scripts (0/5)	Deploy Container	Forge Web Credentials (0/2)	Cloud Storage Object Discovery	Replication Through Removable Media	Clipboard Data	Dynamic Resolution
Search Closed Sources (0/2)	Obtain Capabilities (0/7)	Replication Through Removable Media	Input Injection	Create Account (0/7)	Create or Modify System Process (1/5)	Domain or Tenant Policy Modification (1/2)	Input Capture (0/4)	Container and Resource Discovery	Software Deployment Tools	Data from Cloud Storage	Encrypter Channel
Search Open Technical Databases (0/5)	Stage Capabilities (0/9)	Supply Chain Compromise (0/3)	Inter-Process Communication (0/3)	Create or Modify System Process (1/5)	Create or Modify System Process (1/5)	Email Spoofing	Modify Authentication Process (2/8)	Debugger Evasion	Faint Shared Content Settings to Replicate Windows	Data from Configuration Repository	Fallback Channels
Search Open Websites/Domains						Execution Guardrails (0/2)	Domain Trust Discovery				Hide Infrastructure

legend

Two of the mapped APTs have shown high-frequency techniques. Some of the high-frequency techniques include External remote service (T1133), network service discovery (T1046), Protocol tunnelling (T1572), Email collection (T1114), and Ingress tools transfer (T1105).

OVERLAY

mitre-attack.github.io/attack-navigator/

Indrik Spider x APT-C-36 x Cobalt x Unit 29155 x Shark Spider x layer by operation x

Selection Controls Layer Controls Technique Controls

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection
11 techniques	8 techniques	11 techniques	17 techniques	23 techniques	14 techniques	47 techniques	17 techniques	34 techniques	9 techniques	17 techniques
Active Scanning (2/3)	Acquire Access	Content Injection	Cloud Administration Command	Account Manipulation (3/7)	Abuse Elevation Control Mechanism (1/6)	Abuse Elevation Control Mechanism (1/6)	Adversary-in-the-Middle (0/4)	Account Discovery (3/4)	Exploitation of Remote Services (0/4)	Adver the-M (0/4)
Gather Victim Host Information (0/4)	Acquire Infrastructure (2/8)	Drive-by Compromise	Command and Scripting Interpreter (5/13)	BITS Jobs	Access Token Manipulation (0/5)	Access Token Manipulation (0/5)	Brute Force (1/4)	Application Window Discovery	Internal Spearphishing	Archiv Collect Data
Gather Victim Identity Information (1/3)	Compromise Accounts (0/3)	Exploit Public-Facing Application	Container Administration Command	Boot or Logon Autostart Execution (0/14)	Account Manipulation (0/5)	Build Image on Host	Credentials from Password Stores (1/6)	Browser Information Discovery	Lateral Tool Transfer	Audio Captu
Gather Victim Network Information (0/6)	Compromise Infrastructure (1/8)	External Remote Services	Deploy Container	Boot or Logon Initialization Scripts (1/5)	Account Manipulation (3/7)	Debugger Evasion	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (0/2)	Auton Collec
Gather Victim Org Information (0/4)	Develop Capabilities (1/4)	Hardware Additions	ESXi Administration Command	Cloud Application Integration	Boot or Logon Autostart Execution (1/14)	Deobfuscate/Decode Files or Information	Forced Authentication	Cloud Service Dashboard	Remote Services (3/8)	Brows Sessic Hijack
Phishing for Information (3/4)	Establish Accounts (2/3)	Phishing (3/4)	Exploitation for Client Execution	Compromise Host Software Binary	Boot or Logon Initialization Scripts (1/5)	Deploy Container	Forge Web Credentials (0/2)	Cloud Storage Object Discovery	Replication Through Removable Media	Clipbo Data
Search Closed Sources (0/2)	Obtain Capabilities (3/7)	Replication Through Removable Media	Input Injection	Create Account (1/3)	Create or Modify System Process (1/5)	Domain or Tenant Policy Modification (2/2)	Input Capture (0/4)	Container and Resource Discovery	Software Deployment Tools	Data f Cloud Storag
Search Open Technical								Debugger Evasion		

legend

	A	B	C	D	E	F
1	Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation
2	Active Scanning	Acquire Access	Content Injection	Cloud Administration Command	Account Manipulation	Abuse Elevation Control Mechanism
3	Gather Victim Host Information	Acquire Infrastructure	Drive-by Compromise	Command and Scripting Interpretation	BITS Jobs	Access Token Manipulation
4	Gather Victim Identity Information	Compromise Accounts	Exploit Public-Facing Application	Container Administration Command	Boot or Logon Autostart Execution	Account Manipulation
5	Gather Victim Network Information	Compromise Infrastructure	External Remote Services	Deploy Container	Boot or Logon Initialization Scripts	Boot or Logon Autostart Execution
6	Gather Victim Org Information	Develop Capabilities	Hardware Additions	ESXi Administration Command	Cloud Application Integration	Boot or Logon Initialization Scripts
7	Phishing for Information	Establish Accounts	Phishing	Exploitation for Client Execution	Compromise Host Software Binaries	Create or Modify System Process
8	Search Closed Sources	Obtain Capabilities	Replication Through Removable Media	Input Injection	Create Account	Domain or Tenant Policy Modification
9	Search Open Technical Databases	Stage Capabilities	Supply Chain Compromise	Inter-Process Communication	Create or Modify System Process	Escape to Host
10	Search Open Websites/Domains		Trusted Relationship	Native API	Event Triggered Execution	Event Triggered Execution
11	Search Threat Vendor Data		Valid Accounts	Poisoned Pipeline Execution	Exclusive Control	Exploitation for Privilege Escalation
12	Search Victim-Owned Websites		Wi-Fi Networks	Scheduled Task/Job	External Remote Services	Hijack Execution Flow
13				Serverless Execution	Hijack Execution Flow	Process Injection
14				Shared Modules	Implant Internal Image	Scheduled Task/Job
15				Software Deployment Tools	Modify Authentication Process	Valid Accounts
16				System Services	Modify Registry	
17				User Execution	Office Application Startup	
18				Windows Management Instrumentation	Power Settings	
19					Pre-OS Boot	
20					Scheduled Task/Job	
21					Server Software Component	
22					Software Extensions	
23					Traffic Signaling	
24					Valid Accounts	
25						

Overlay Picture

The above picture shows the overlaying of the five (5) APT groups mapped in MITRE ATT&CK Framework using MITRE ATT&CK Navigation. The purpose of this overlay is to identify common techniques used across the five threat actors so we can prioritize defenses where they matter most. It also validates the current security posture.

Overlay turns multiple separate threat profiles into a single weighted layer that shows:

- Most frequently used techniques
- Techniques used by only a few groups
- Gaps in the current defence.

Across the threat groups, **Indrik Spider**, **Unit 29155**, and **Shark Spider** Techniques were consistently observed, showing a focus on Initial Access, Lateral Movement, Discovery, and Command. and Control.

Initial Access

APTs	Techniques Observed	Notes
Indrik Spider	Valid Account (T1078)	Target domain account
Unit 29155	Supply Chain Compromise (T1195.001)	Compromise software dependencies
Shark Spider	External Remote Services(T1133)	Vendor access to the internal network.

Command and Control

APTs	Techniques Observed	Notes
Indrik Spider	Ingress Tool Transfer(T1105)	Data exfiltration
Unite 29155	Non- Standard Port(T1571)	network filtering and detection
Shark Spider	Web Services(T1102)	Bidirectional Communication

Discovery

APTs	Techniques Observed	Notes
Indrik Spider	Remote System Discovery(T1018)	Primarily use native OS commands
Unite 29155	Log Enumeration(T1654)	Often used to uncover actionable intelligence
Shark Spider	Account Discovery (T1087.004)	Targets listing of the cloud account

Task 4: Detection & Control Mapping (NIST & ISO)

APTs TACTICS	NIST CSF FUNCTION	KEY CSF
Initial Access	Protect (PR)	Controls such as access control, email filtering, MFA, and user training are designed to prevent attackers from gaining access.
Lateral Movement	Detect (DE), Protect (PR)	Once inside, lateral movement is typically uncovered via monitoring, logging, and anomaly detection. abnormal authentication or east-west traffic

Discovery	Detect (DE)	Discovery activity (network scans, account enumeration) is identified through behavioural and activity monitoring.
Command and control	Detect (DE), Protect (PR)	Command and control rely on outbound communications, which are usually detected through network monitoring and traffic analysis. DNS filtering and network segmentation to block or hinder C2 channels.

Task 4b. Mapping Relevant Control Theme to ISO/IEC 27001

Finding / Activity Observed	Relevant ISO/IEC 27001 Control Theme	How it Maps
Initial Access (e.g., phishing, credential abuse, exploitation)	Access Control	Weak authentication, authorization, or identity management enables unauthorized entry.
	Human Resource Security	User awareness and training failures often enable phishing-based access
	Operations Security	Patch management and secure system configuration failures are common entry points.

Lateral Movement	Access Control	Excessive privileges and weak role separation allow attackers to move between systems.
	Communications Security	Lack of network segmentation and insufficient internal traffic controls enable east-west movement.
	Operations Security	Inadequate logging, monitoring, and hardening facilitate undetected movement.
Discovery (e.g., Network scanning, Account enumeration)	Operations Security	Monitoring, logging, and event correlation should detect reconnaissance activity.
	Asset Management	Poor visibility into systems and accounts makes a discovery easier for attackers.
Command and Control (C2)	Communications Security	Insufficient network monitoring, DNS controls, or egress filtering allows C2 traffic.
	Operations Security	Failure to detect abnormal outbound connections and malware behaviour.
	Incident Management	Delayed detection or response allows C2 channels to persist.

How the controls reduce exposure to the overlapping TTPs.

The implemented information security controls reduce exposure to identified overlapping threat tactics and techniques (Initial Access, Discovery, Lateral Movement, and Command and Control) by limiting attack vectors, restricting unauthorized activity, increasing detection capability, and enabling timely response.

Access Control

Access control measures reduce the likelihood and impact of unauthorized access by enforcing strong authentication mechanisms, least-privilege access, and role-based access controls. These measures limit the ability of threat actors to obtain initial access using compromised credentials and restrict their capability to enumerate accounts, access sensitive resources, or move laterally within the environment.

Operations Security

Operational security controls, including secure system configuration, patch management, logging, and continuous monitoring, reduce exposure by minimizing exploitable vulnerabilities and increasing the likelihood of detecting abnormal or malicious activity.

Communications Security

Communications security controls, such as network segmentation, traffic filtering, and monitoring of outbound connections, restrict unauthorized network communications and internal movement. These measures reduce the ability of threat actors to propagate laterally across network segments and to establish or maintain external command-and-control channels.

Asset Management

Asset management controls provide accurate visibility into information assets, ensuring systems are identified, classified, and appropriately protected. This reduces the effectiveness of reconnaissance and discovery activities by limiting the availability of unmanaged or unknown assets that could be exploited for further access or movement.

Human Resource Security

Human resource security controls, including security awareness and training, reduce the likelihood of successful social engineering and phishing attacks. These controls address common initial access vectors by improving user behaviour and awareness of information security responsibilities.

Incident Management

Incident management controls enable the timely identification, containment, and remediation of security incidents. Defined response procedures support rapid isolation of affected systems, limiting lateral movement and terminating command-and-control activity before further impact occurs.